

GOLDEN CRUNCH BISCUITS LTD.

Cybersecurity & Risk Management Division

INCIDENTS RESPONSE PLAYBOOK

Business Email Compromise (BEC) Attack

Executive Summary

This playbook provides Golden Crunch Biscuits.Ltd with a structured step by step framework for detecting, containing, eradicating and recovering from a Business Email Compromise (BEC) attack ,Ransomware & DDOS Attack. It is built around a fictional attack scenario involving the fictional parties named below and is intended for use by the Security Operations, Finance, Legal and Executive teams of the company.

BEC attacks are among the most financially damaging forms of cybercrime to ever exist. According to the Internet, BEC schemes accounted for billions in reported losses annually. Unlike malware based attacks, BEC relies almost exclusively on social engineering; exploiting trust, urgency and impersonation rather than technical vulnerabilities.

Aim & Objective of this Playbook : Equip Golden crunch Biscuits workers with the knowledge, procedures and decision authority to respond effectively to a BEC incident within defined MTTR targets,minimise financial loss.preserve evidence for forensic investigation and meet regulatory notification obligations.

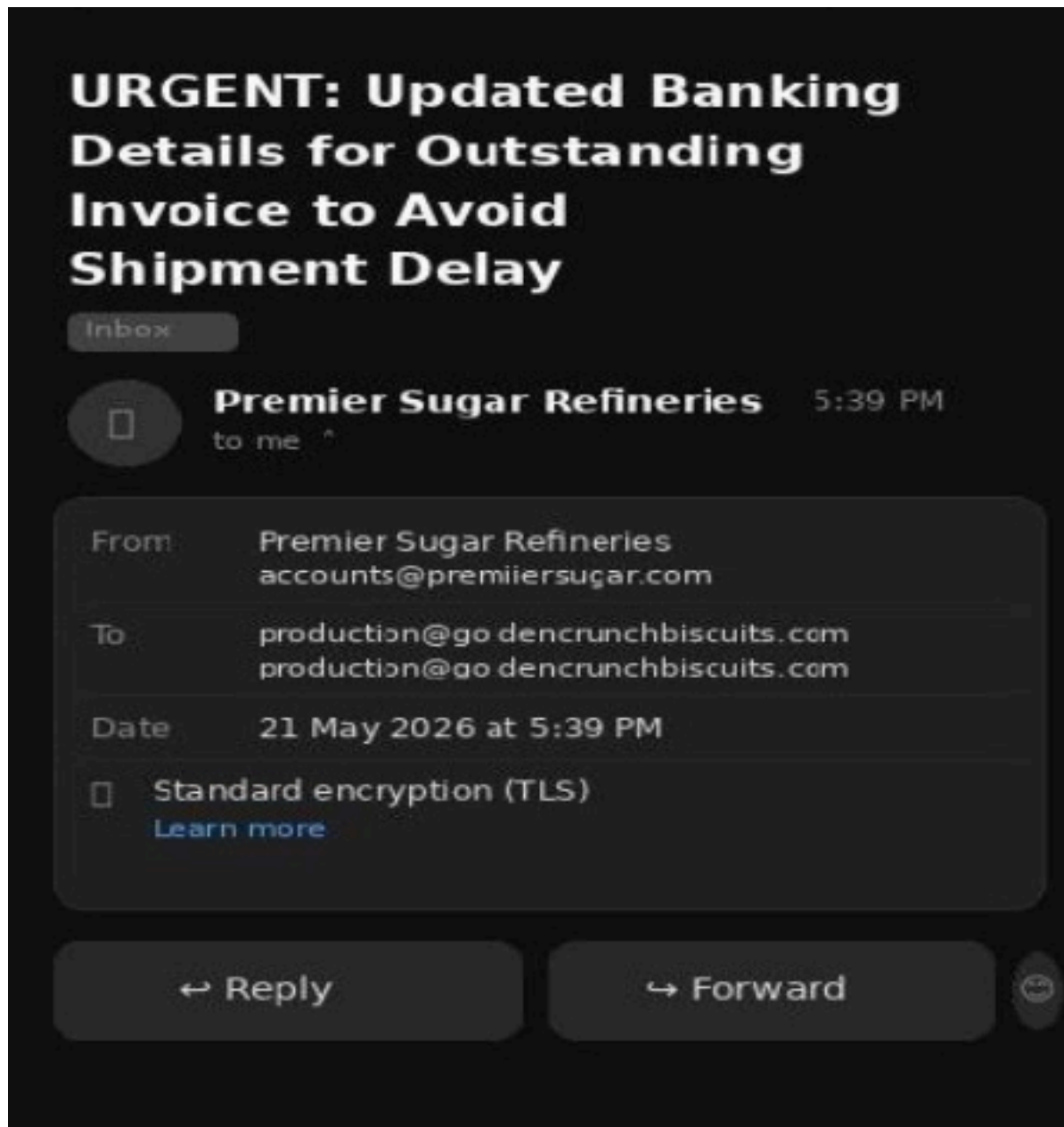
BEC Scenario

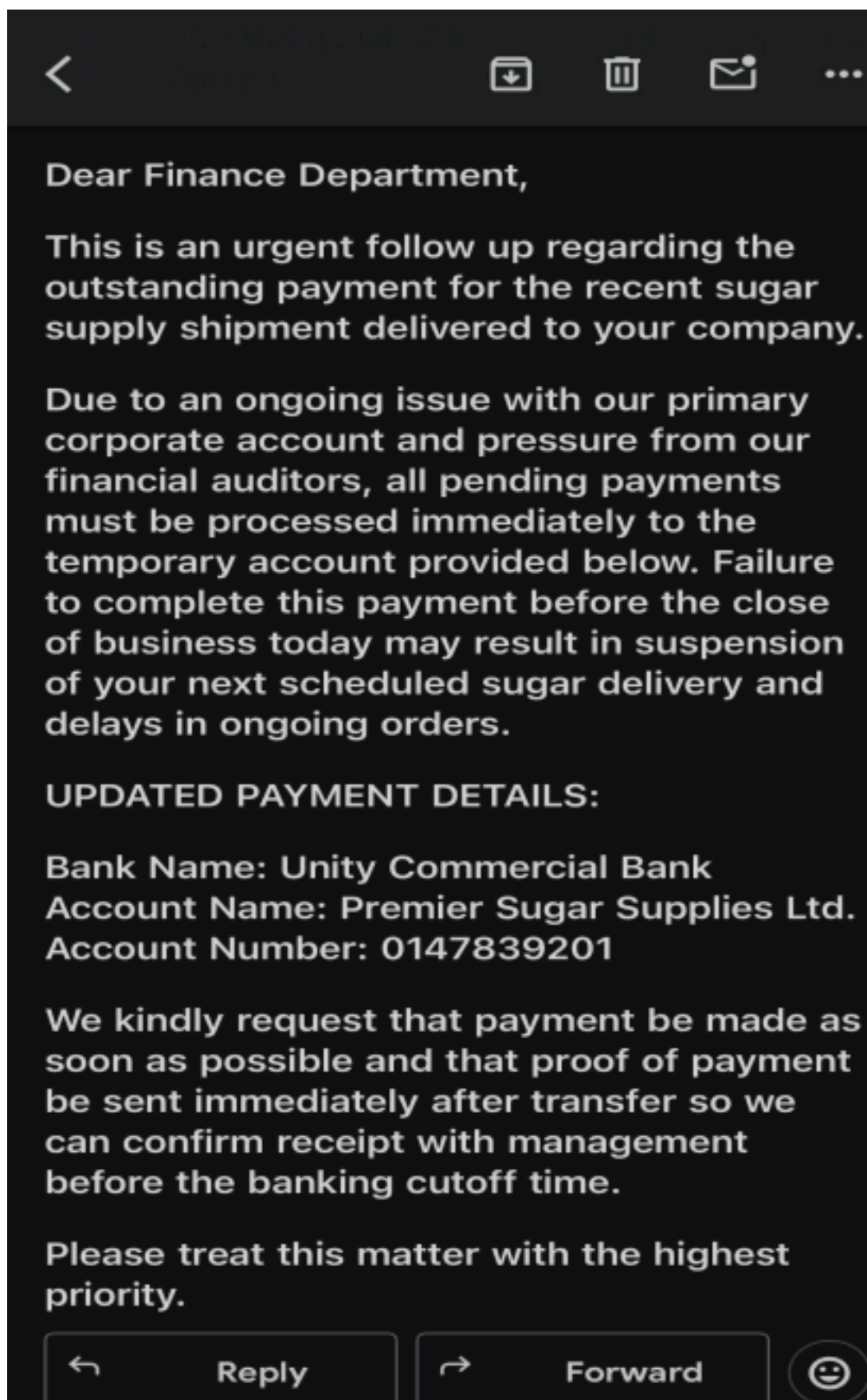
Scenario Overview

The following scenario is entirely fictional, created for company personnel training, educational purposes and playbook validation purposes. Any resemblance to real organisations or individuals is highly coincidental.

Golden Crunch Ltd is a medium sized food manufacturing company that deals with biscuit production that regularly purchases industrial sugar supplies from Premier Sugar Refineries Ltd. The two companies have maintained a trusted business relationship for the past five years and counting, with regularly weekly and monthly transactions. Premier Sugar Refineries communicates with Golden Crunch Biscuits

through its official finance department email: accounts@premiersugar.com. As a result of the long standing relationship that has been existing between both companies, employees in the finance department at Golden Crunch Biscuits were familiar with the supplier's invoicing procedures and often processed payments quickly to avoid delays in the production. On 21st of May 2026, the finance department at Golden Crunch Biscuits received the following suspicious email from an impersonation email pretending to be Premier sugar.





Incident Identification

TRIGGERS	INDICATORS
.	EM - Splunk,Microsoft Sentinel rrelates and monitors logs from multiple

	sources.
• EDR— CrowdStrike Falcon,Microsoft Defender for Endpoint	Detects suspicious activities on the endpoint and responds to threats.
• IDS/IPS – Snort, Suricata	Detects and blocks malicious traffic.
• Firewall – Palo Alto NGFW,Cisco ASA	Monitors. filters and blocks connections to known malicious Ips with unusual traffic.
• Email Security Gateway – Mimecast, Microsoft Defender for Office 365	Detects and blocks fake or spoofed addresses,links and attachments.
• DNS Filtering – Cisco Umbrella, Cloudfare Gateway	Detects and blocks access to malicious websites and domains.
• Threat Intelligence – VirusTotal,Misp	Provides information on known threats by matching suspicious Ips,URLs and files against threat databases.

Incident Response Phases:

1. Detection Phase: This is the first phase of an incident response to identify the triggers of an incident.

1. Start with the triggers: detection begins when someone notices an unusual activity and calls attention towards the trigger.
2. Preservation of evidence: Before any action should be taken, evidences of the compromise must be taken and preserved before investigation proceeds.
3. Analysis of the email headers: Check the actual sender of the email and ensure the domain name of the email is authentic and not an impersonation domain. Look out for any irregular characters within the sender address (accounts@premiiersugar.com) There are double I in the email address, indicating a fake email.
4. Check gateway logs for campaign scope: search all employee emails if there are others who got the same email.
5. Interview the person whom received the email and ask necessary questions .
6. Review authentication logs for the impersonated account or email.
7. Search for inbox rules and query the SIEM using the IOCs identified.
8. Assign Severity and Escalate the process.

2. Containment Phase: immediate actions should be taken upon confirmation that a BEC incident is underway or has taken place, the following actions must be executed in parallel by members of the designated teams.

Finance Actions	IT/Security Actions
1. Contact the company's bank immediately using the verified telephone number on file (do not contact any number provided in the suspicious email) and request a payment freeze.	1. Quarantine the suspicious email from all inboxes across the organization without deleting it.
2. Suspend all pending payment instructions to the affected supplier until verification is complete.	2. Preserve full email headers and submit them to the SOC for forensic analysis.
3. Do not communicate with the attacker in any way or through any medium.	3. Block the impersonator's domain (accounts@premierisugar.com) at the email gateway and DNS level.
4. Take record of all email correspondence, including headers without forwarding or deleting.	4. Check all accounts payable staff email accounts for signs of compromise including unexpected forwarding rules and login anomalies.
	5. Pull authentication logs for the affected staff member's account 30 days before the incident.

3. Eradication Phase: This phase focuses on the removal of the attacker's foothold and closing all vulnerabilities exploited during the attack.

Email Environment

- Remove any mail forwarding rules created by or for the attacker across all affected accounts.
- Restrict access to any OAuth tokens or third party app permissions granted during the compromise to prevent future compromise.
- Scan all the staff inboxes for emails originating from the attacker's

impersonation domain and quarantine them.

- Submit the attacker's impersonation email to the email security vendor's threat intelligence feed for global blocking and prevent future occurrence.
- Backup relevant information that can be lost during this process so they can be restored after the attack has been taken care of.

Supplier Records

- Review and validate all supplier banking details in the accounts payable system against original onboarding documents and domains. Flag any records that changes have been made to in the last 90 days for 2 factor authentication.
- Implement a mandatory dual authorization requirement for any future changes to the supplier banking records.
- Contact all active suppliers to verify their current banking details through a voice call to their registered number.

Identity and Access

- Force a password reset for all accounts payable
- Perform a proper Audit on privileged accounts for any change during the period of the incident.

4. Recovery Phase: This process focuses on the actions to take after an incident took place and steps to take to prevent further occurrence.

1. Fix every vulnerabilities detected after and during the attack.
 2. Reset all passwords for all the affected accounts and create new accounts if the affected accounts need to be disabled permanently.
 3. Keep tabs on malicious activities related to this incident for an extended period.
 4. In case of data loss or financial loss, consult the necessary Personnels.
- **Financial Recovery:** If funds have already been transferred, recovery depends heavily on the speed of intervention. The following actions should be followed step by step.

Action	Timeline
Request payment recall via the company's bank	Immediately upon discovery
File a complaint with the cybercrime department	Within 24 hours

Call the attention of local authorities and national cybercrime department	Within 24 hours of the incident.
Engage cyber insurance provider and open a complaint file	Within 45 hours
Engage a specialist financial fraud recovery firm if the transfer is between countries	Within 72 hours

Roles and Responsibilities

Effective incident response requires clearly assigned roles with defined authority, the following personnel and teams carry the responsibilities under this section of the playbook.

Roles	Responsibilities
Executive Sponsor	Board notification, major decisions, public disclosure and resource allocation.
Incident Commander	Manages and coordinates all teams, documents decisions, communicates with stakeholders.
Security Operations Lead	Oversees the entire SOC team, strategic planning and technical investigation.
Soc Analyst	Hands on detection, in-depth analysis, and threat hunting.
Finance Lead	Financial assessment, immediately freezes suspicious payments, and reviews

	transactions for fraud.
IT Lead	Technical containment, locks compromised accounts, hardens systems to prevent reentry.

Legal & Compliance	Protects the company legally, ensures data protection laws are followed, handles privilege considerations.
Communication Lead	Manages media and controls reputational damage, drafts internal and external communications.

Communication Strategy:

Internal Communication:

Audience	Method	Time
Finance Team	The Incident Commander contacts the Finance Director directly as soon as the incident is discovered, followed by a written notification confirming the details.	Immediately upon discovery.
All Staff	The communications Lead sends out an internal email to all staff advising them not to act on any suspicious emails and to report anything unusual to their manager	Within 2 hours of the incident being confirmed.
Senior Management	The Incident Commander contacts senior management directly by phone to brief them on the situation and updates are given every hour while the attack is	Immediately upon confirmation.

	active.	
--	---------	--

Board of Directors	The Executive Sponsor prepares and delivers a formal written briefing to the board outlining what happened, the current situation and potential business impact.	Within 24 hours of the incident being confirmed.
--------------------	--	--

External Communication:

Audience	Method	Time
Company Bank	The Finance Director contacts the company's bank directly using the verified telephone number on file. Under no circumstance should any contact number provided in the suspicious email be used.	Immediately upon discovery of the incident
Law Enforcement / Cybercrime Department	Legal and Compliance files a formal report with the local cybercrime department and notified national authorities if necessary.	Within 24 hours of the incident being confirmed.
Affected Clients	The Communications Lead sends an official notification to any client whose information may have been involved in the incident.	Within 48 hours if their data was involved.

Regulators	Legal and Compliance submits a formal compliance report to the	Within 72 hours of the incident.
------------	--	----------------------------------

	relevant regulatory body as required by data protection laws.	
Media	Press enquiries should be handled by the Communications Lead. An official statement is prepared only if the incident becomes public.	Only if the incident becomes public.

Metrics:

Metrics	Description	Targets
MTTD	Time taken to identify threats.	Under 24 hours
MTTR	Time taken to contain and remediate incidents.	Under 5 hours
Number of Incidents	Total detected, investigated and resolved.	Record total number during investigation.
False Positive Rate	Indicates efficiency of detection tools.	Record and review after incident.
Financial Loss	Total amount lost or at risk exposed	escalate immediately if loss is confirmed.
Accounts Compromised	Total amount of email accounts affected.	Record exact number, escalate if more than 3 accounts.

Ransomware Incident

Incident Severity: Critical

Document Reference: ASC-IRP-RANSOMWARE-001

Threat Family: NetWalker Ransomware(Case study + General Ransomware Guidance)

Executive Summary

This Playbook provides the necessary steps to take with structured framework for detecting ,containing. Eradicating and recovering from ransomware attacks. It is built around Netwalker case study but also includes general ransomware response procedures applicable to other areas e.g Lockbit , Conti, Ryuk.

Ransomware Scenario – Netwalker Case Study

Victim Host	FIN-WS-014 (Finance Department Workstation)
User Context	goldencrunchbiscuits\m.nkosi (Accounts Payable Officer)
Initial Vector	Phishing email with a malicious invoice attachment
Execution	winword.exe – poershell.exe – cmd.exe – vssadmin.exe
impact	Finance drives, ERP backups and local documents are encrypted
Exfiltration	TOR outbound traffic, 48MB data transfer in 90 seconds
Key Lesson	Secondary human review and rapid isolation are at a critical level

Roles and Responsibilities

Role	Individual/Team	Responsibility
Incident Commander	CISO or Delegate	Overall coordination,

		escalation of decisions
SOC Lead	Soc Manager	Technical Investigation, log analysis and evidence preservation
IT Infrastructure	Head of IT	Host isolation, rebuilds, patching
Finance Lead	Finance Director	Business Continuity
Legal & Compliance	General Counsel	Regulatory notification, law enforcement
Communication Lead		Corporate affairs Internal messaging
Executive Lead	CEO/CFO	Board Notification, disclosure approval

1. Detection and Identification

The following indicators of compromise (IoCs) would trigger urgent escalation to the Security Operations Team for Immediate Investigation.

- When files are renamed with extensions like .e76748, .locked, .encrypted, • The SOC team should immediately begin investigation on SIEM correlation alerts, NSM monitoring alerts should also be enabled and employees should report suspicious activities to determine if ransomware execution is actively ongoing.
- Analysts should review endpoint telemetry, windows event logs and authentication logs activity to identify concrete IoCs such as malicious file hashes, suspicious parent child process relationships and other anomalies that are consistent with ransomware behaviour.
- Intense attention should be placed on suspicious detection execution chains involving legitimate administrative tools . The execution patterns are commonly associated with phishing based ransomware delivery.
- The SOC team should determine whether the attack has spread beyond the initial detected endpoint by doing a thorough review of systems with similar

users.

- Analysts should also investigate potential Command and Control (C2) communications by reviewing firewall logs, IDS/IPS alerts, DNS activity, EDR network telemetry, proxy logs, NetFlow data, router and TOR related traffic, encrypted beaconing activity and unauthorised external communications.

Once these IOCs are detected, the SOC team must immediately move to detect the nature and source of the anomaly.

General Detection Commands:

1. Linux: `sudo grep -r "encrypted" /var/log/`
2. Windows: Monitor for abnormal PowerShell/WMI execution and mass file renaming

Furthermore, the major detection Channels to use are SIEM correlation alerts, EDR behavioural detection, NSM monitoring for TOR/C2 traffic, Employee reports of suspicious activity, firewall/IDS/DNS logs, netflow or router logs.

2. Containment

immediate actions to commence 0-2 hours after initial discovery

1. Isolation of infected host :

- Immediately disconnect the workstation from the corporate network (wired and wireless), then disable VPN or remote access sessions associated with the host. - Tag the device in EDR/SIEM as “quarantined” to prevent reconnection and preserve volatile memory and disc images for forensic analysis before shutting down the system

2. Disable compromised accounts :

- Lock the user account in Active Directory/identity system then force password reset and revoke all active sessions, tokens, and cached credentials - Check for attempts at privilege escalation or lateral movement using the account, and document the time of disablement for proper incident timeline reconstruction.

3. Block malicious IPs/domains to cut off C2 communication

- Add identified TOR exit nodes and suspicious IPs to firewall block lists then update DNS filtering to prevent the resolution of attacker domains/ - Push updated block rules across all perimeter and endpoint security devices and monitor logs to confirm no further outbound traffic to these destinations.

4. Suspend backup jobs to prevent encryption spread

- Put a pause to any scheduled backup tasks to avoid encrypting clean backup sets, and go on to disconnect backup servers or storage from the production network.

- Validate the last known good backup snapshot and preserve it offline before notifying the Backup/DR team to prepare for restoration only when containment has been completed.

5. Linux containment

- Drop traffic from malicious IPs using iptables: *sudo iptables -A INPUT -s <malicious_IP> -j DROP*
- Switch the system to rescue mode to limit its services: *sudo systemctl isolate rescue.target*
 - Preserve system logs and process lists for forensic review and ensure containment commands are logged and timestamped for audit purposes.

NOTE: Do not attempt to shut down or reboot an infected system before forensic capture. Shutting down prematurely can destroy volatile evidence and make recovery complicated.

Short-Term Containment (2–24 Hours)

Reset credentials for any account suspected of compromise, then enforce Multi Factor Authentication re-enrolment

- Immediately force password resets for accounts that show suspicious activity or infected hosts
- once completed, insist on MFA re-enrolment across end devices, this ensures that any extracted token or cached credentials cannot be used again on the threat actors end.
- Lastly, audit privileged accounts for unusual logins. Privilege escalation attempts or changes made during the incident time frame to determine any attempts of data exfiltration.

Network containment and monitoring

- It's essential to segment the affected VLANs or subnets to prevent further spread of ransomware, then restrict SMB traffic and disable unnecessary file sharing services across the network environment
- Simultaneously monitor logs for new outbound connections to suspicious IPs, TOR nodes or domains associated with ransomware infrastructure.

Incident coordination

- Before briefing the finance director and CISO on the situation, inform the incident response team within four hours of the confirmed incident.
- Ensure there is a well documented and detailed timeline of events with timestamps, including detection, containment actions and system changes. As these are essential for proper documentation.

- Begin drafting of internal communication to staff, however. Its essential to delay release until containment is confirmed to avoid confusion.

3. Eradication

Eradication focuses on removing the attacker's foothold and closing the vulnerabilities exploited during the attack. The following steps should be taken to ensure proper removal of any traces left behind.

1. Patch exploited vulnerabilities

- Apply security patches to all operating systems, applications and remote access services that were exploited to prevent re-infection by the attacker. - Initiate validation patch deployment across all systems that were affected by the attack before confirming that the vulnerable services are no longer exposed. - It is not ideal to deploy custom signatures to endpoint protection and network security tools, depending on the discovered IOCs.

2. Reset compromised credentials

- All accounts on the infected host systems should be reset, this includes the service accounts and the administrative credentials.
- It is also imperative to rotate or change API keys, certificates, and other authentication tokens that may have been exposed during the attack - Rebuild infected systems from known good media, making sure to only restore from known and trusted clean backups.
- Lastly, confirm endpoint protection (AV, NGAV, EDR, etc.) is up-to-date and enabled on all systems.

3. Preserve forensic evidence before wiping systems

- It is essential to capture disk images, memory dumps and log files from infected machines before reimaging or wiping.
- At the same time, store evidence securely for later forensic analysis, insurance claims and potential legal proceedings.

4. Submit attacker domains to threat intelligence feeds

- Report malicious domains and IPs to email security vendors, DNS filtering providers, and threat intelligence partners
- Ultimately, ensure to block all the attacker's infrastructure globally across DNS, email gateways, and firewalls to prevent reinfection.

Reminder: Watch for reinfection! It is crucial to set up alarms/alerts for this incident.

4. Recovery

Financial and Operational Recovery are an important part of every business and industry. Companies may not always be able to set up drills for pre-emot attacks, but a solid recovery plane is still helpful to restore operations back to normal while managing costs ,reducing period of downtime and ensuring crucial services after

ransomware attack(s)

- Restore from offline backups ; drives and cloud backups
- Validate backup integrity before recovery
- Linux verification: ls -la /etc/shadow / etc/passwd
- Prioritise restoration by business criticality
- Monitor for reinfection before reconnecting

5. Notification and Reporting Obligations

Stakeholder	Trigger	Timeframe	Owner
Board of Directors	Any confirmed ransomware incident	24 hours	CISO/CEO
Data Protection Authority	If personal data is affected	72 hours	Legal
Cyber insurance Provider	Financial impact	48 – 72 hours	CFO
Law Enforcement (DSS)	Confirmed Ransomware	24 hours	Legal
Affected Suppliers/ Stakeholders	If Supplier identity is affected	24 hours	Comms Lead
Internal Staff	After containment	48 hours	Comms Lead/CISO

Critical Info: Do not attempt to engage with or pay the ransom demanded by the attacker without executive and legal approval. Unauthorised negotiation or payment may violate regulations and encourage further attacks.

6. Post Incident Review

After every ransomware attack, whether contained early or fully executed, it is essential to pause and reflect. Threat actors constantly evolve their tactics and each accident

provides valuable lessons that can strengthen the organization's resilience. A well structured post incident review ensures that Golden Crunch Biscuits not only recover from the event but also emerges better prepared for any other challenge or threat

actors may pose.

Control Improvements

Based on the answers to these questions, the following improvements should be prioritise amongst others

1. immutable and well segmented backups: backups can be better protected from being altered or encrypted by ransomware when they are stored in isolated environments.
2. Stronger phishing defences and macro restrictions: This reduces the likelihood of initial compromise through educating staff on malicious looking attachments or links. They should also be encouraged to report such links immediately rather than deliberating on engagement.
3. Privileged access management: Proper RBACs should limit the ability of attackers to escalate privileges and move laterally.
4. Endpoint isolation protocols: it is of great importance to streamline the process of quarantining infected devices, which helps to prevent further spread.
5. Annual ransomware drill exercises: Plan and conduct regular activities for teams to practice and test their level of competence under pressure.

Distributed Denial of Service(DDoS) Attack A

DDoS attack (Distributed Denial of Service attack) is a cyberattack designed to make a website, server, network, or online service unavailable to legitimate users. **How it works**

Instead of one computer sending excessive traffic, a DDoS attack uses many devices (sometimes thousands or millions) to flood a target with requests simultaneously. These devices may be part of a botnet:- a network of compromised computers, phones, cameras, or other internet-connected devices controlled by an attacker.

Scenario Overview

An adversarial threat group launches a massive multi vector volumetric and application layer DDoS attack targeting Golden Crunch Biscuits primary public facing web portal.

A malicious botnet floods the corporate web hosting tier with over 50 Gbps of synthetic traffic consisting of concurrent UDP floods and a very high frequency of LAYER 7 & HTTP POST requests. This traffic rapidly exhausts the web server connection queues of the company, this causes the application gateways to time out and knocking the entire e-commerce application offline or cause very high level of traffic causing slow buffering for real global users trying to access the website.

Incident Identification: Triggers & Indicators

The Security Operations Center (SOC) will Automatically flag this incident via three clear operational triggers:

- **Edge interface saturation (Layer 3/4):** Network monitoring dashboards trigger critical severity alarms as inbound bandwidth utilization surpasses the usual 95 % of total physical line capacity at the perimeter routers.
- **Application Gateway Disruption (Layer 7) :** Automated external synthetic monitors and load balancers record an immediate and sustained spike in HTTP 502 (Bad Gateway) and HTTP 504 (Gateway Timeout) responses.
- **Infrastructure Resources Exhaustion:** Centralized infrastructure logs show backend application server pools pinned at 100% CPU and RAM utilization, entirely driven by unauthenticated repeated connection requests.

Incident Response Phases (Technical Workflows)

1. Detection & Analysis

- Traffic profiling & classification : Run deep packet inspection scripts via edge netflow analyzers to classify the attack vectors e.g distinguishing layer 4 UDP? DNS amplification traffic from Layer 7 & HTTP floods)
- Signature Extraction: Isolate repeating characteristics within the malicious traffic stream. These includes identifying specific malicious user agent strings targeted URL query strings and patterns in source Autonomous System Numbers (ASNs)
- Secondary Intrusive Checking: Query internal security information and Event Management (SIEM) event logs to verify that the high volume DDoS attack is not a noisy diversion tactic designed to mask a silent database intrusion or data exfiltration attempt or an unrelated diversion.

2. Containment

- **Scrubbing Center Diversion :** Change the external DNS authoritative routing or trigger an emergency Border Gateway Protocol (BGP) route announcement to instantly divert all public inbound web traffic through a cloud based DDoS scrubbing provider e.g Cloudflare or AWS Shield Advanced)
- **Web Application Firewall (WAF) Hardening:** Deploy custom regex WAF rules at the cloud edge to automatically drop incoming packets matching the specific browser signatures or rogue ASNs identified during the analysis phase.
- **Connection Rate Limiting :** Modify Load balancer configuration parameters to enforce strict IP connection limits which automatically drops traffic from single sources that exceed normal baseline application usage thresholds.

3. Eradication

- **Upstream Carrier Filtering:** Coordinate directly with the enterprise Tier 1 Internet Service Providers (ISPs) to drop malicious volumetric traffic upstream before it ever hits the organization's local physical network pipes using the Remotely Triggered Black Hole (RTBH) routing.
- **Malicious IP Blocklisting:** Feed live threat intelligence feeds containing known botnet command and control (C2) IP Spaces directly into the perimeter firewall blocklists

4. Recovery

- **Incremental Policy Relaxation :** Gradually lower the aggressive edge WAF restrictions and geoblocking parameters back to standard baselines as incoming synthetic traffic levels return to normal.
- **Connection State Cleansing:** Forcibly restart web server service daemons (e.g., Nginx, Apache) and flush database connection pools to clear out dead, hung, or orphaned half-open connections caused by the flood.
- **Multi Node Latency Verification:** Monitor response times, availability metrics, and end-user transaction success rates from multiple global geographic testing nodes for the next 48 hours to guarantee full, stable restoration of services.

5. Roles And Responsibilities

The Response Coordination is distributed among the following explicit enterprise security roles:

Role	
Incident Commander (IC)	Acts as the ultimate decision maker. authorizes financial spending increases for scaling cloud scrubbing capacity and aligns executive leadership

Network Security Lead	Coordinates directly with the upstream ISPs, builds and deploys custom edge WAF rules and monitors real times traffic scrubbing dashboards
Public Relations(PR) Lead	Owns the external messaging strategy updates public facing company status indicators and handles media inquiries.

6. Communication Strategy

- **Internal Communications:** Sends a brief high level status broadcast to department heads explaining the network degradation and detailing the active mitigation steps. Move technical discussion entirely to an out of band communication channel e.g an independent chat group) as internal communications can slow down or experience crash under network resource exhaustion.
- **External Communications:** Direct the PR lead to publish a notice on an externally hosted independent company Status page acknowledging a temporary performance drop explicitly clarifying that user data remains safe and providing scheduled updates to reduce inbound customer support ticket volumes.

Success Metrics (KPIs)

The efficiency of the playbook implementation is graded against three core criteria: -

- **Time to Reroute:** Inbound public traffic must be successfully diverted into the cloud scrubbing center within 12 minutes of initial trigger validation - **Core API Availability:** Maintain greater than 99% operational availability for the underlying backend database APIs during the active attack mitigation period.
- **Legitimate Traffic Blast Radius:** Total Percentage of genuine corporate users accidentally dropped or blocked by aggressive edge rate limiting rules (Organizational Goal should be at a 1% false positive rate)

Strategic design Choices & Readiness

Benefits Behind the Scenes Design Choices

The BEC Playbook

The BEC playbook is built around a fictional supplier payment fraud scenario which reflects how attackers commonly exploit trust and human behavior rather than technical vulnerabilities. The reason for this design choice was the involvement of multiple departments, including Finance, IT, Legal, Communications and Executive Management, making sure that both technical and business impacts are addressed.

The playbook emphasizes preservation of evidence, rapid financial intervention, and supplier verification processes. These measures help reduce;

- Financial losses
- Improve fraud detection

- Strengthen communication between departments
- Enhance compliance with legal and regulatory requirements.

The Ransomware Playbook

The ransomware playbook combines a real world case study with general response procedures applicable to different ransomware samples.

- It focuses heavily on early detection through security monitoring tools, endpoint analysis and network traffic reviews.
- Immediate isolation of infected systems, protection of backups, account lockdowns and network segmentation are central design features aimed at preventing the spread of malware.
- The recovery strategy prioritizes restoring operations from clean backups and conducting post incident reviews to further improve future readiness. As a result, the organization can reduce downtime, protect critical systems, preserve forensic evidence and strengthen its overall resilience against ransomware attacks.

The DDoS Playbook

- **The Selection of Cloud Based Scrubbing over Local Appliances:** On premise firewalls cannot stop a 50 Gbps volumetric attack if the max capacity the internet pipe can accommodate is only 10Gbps. The pipe fills up and crashes. Choosing a cloud based routing model filters the malicious traffic at the global network edge long before it reaches the local infrastructure.
- **Inclusion of the Diversion Check:** Attackers normally use high volume and loud DDoS attacks to overwhelm security teams disytracting them while a separate silent data exfiltration exploit is taking place withiut being detected. This is why a compulsory secondary SIEM review is needed.

Expected Organizational Benefits

- **Minimized Revenue Loss:** Drastically slashes the duration of public web downtime, preserving e-commerce operations
- **Preservation of Corporate Reputation:** Replaces a chaotic response with an orderly, pre-approved customer communication loop that builds client trust during an outage.

Post-Incident Review (PIR) Framework

This section must be completed by the Incident Commander within 48 hours of service stabilization

1. Incident Track Identifier: DdoS-2026-05-26

2. Executive Narrative: (Provides a 3 sentence summary of the downtime duration, the source botnet classification and total estimated operational impact.)

3. Lifecycle Timeline Analysis:

- Time of Initial Saturation: _____
- Time of WAF Rule Enforcement: _____
- Time of Full Traffic Cleanliness: _____

Disclaimer: The playbook opens with a realistic fictional scenario involving Premier Sugar Refineries to make the procedures relatable and easier for GCB staff to apply. The playbook states it is intended for training, educational purposes and playbook validation